畅课 (TronClass) 自动签到方法论剖析与演进路线图

深度解构 auto-Tronclass-APP 开源方案 · 赋能「掌上理工 (usst-jwgl-client)」工程实践

技术白皮书 / 架构指引

适用平台：Android (Kotlin / Jetpack)
生成时间：2026 年 11 月

一、 背景与目标项目架构概览

随着各大高校智慧教学系统的普及，基于 **TronClass（畅课/一网畅学）** 的随堂点名已成为高频考勤场景。开源项目 `hot-YUser/auto-Tronclass-APP`（以下简称 *auto-Tronclass*）是一个以 **Rust 原生核心（Core）+ .NET MAUI / Android 前端** 构建的高性能、跨平台全自动签到与答题工具。

其架构将所有协议抓取、会话持久化、算法解算与平台安全全部下沉至 Rust，通过严格定义的 C ABI 与版本化 JSON 契约与 UI 交互。其核心价值在于证明了**畅课平台的全类型点名均具备闭环自动化反解可能**，并在算法鲁棒性与防封禁机制上具备极高的工业级参考价值。

1. 状态侦测 监听源
`GET /api/radar/rollcalls` 全局探针或定时扫描，支持同租户多学生群组共享发现。

2. 严格正交分类 状态机
按优先级归类为自主（Self）、数字（Number）、雷达（Radar）、二维码（QR）4 种正交原语。

3. 策略解算提交 核心算法
空探针试探 → 测距几何反解 → 严格单飞爆破 → Token 众包，精准分发独立 DeviceId。

4. 权威查册闭环 结果确认
调用 `/student_rollcalls` 逐行核对当前学号是否为 `on_call_fine`，杜绝虚假成功。

二、 畅课自动签到核心方法论深度解构

1. 雷达点名（Radar）：空探针与全球三边测量几何反解（核心亮点）

雷达点名通常包含 GPS 地理范围限制与蓝牙信标。传统方案依赖真实 GPS 或固定教学楼坐标，一旦教师在操场、临时换教室或有 GPS 漂移即失效。auto-Tronclass 挖掘了畅课后端的关键漏洞：

- **漏洞机理与双阶解算机制：**

阶梯 ①（空 Body 轻量探针）： 直接向 `/api/rollcall/{id}/answer` 发送 `{}`。多所高校租户虽开启雷达点名，但未在管理后台强制勾选"严格校验 GPS 范围"，此时空请求直接秒签。

阶梯 ②（服务端距离泄露与 WGS84 大圆几何反解）： 当开启范围校验时，提交任意错误坐标，服务器返回 200，但附带错误与距离：`{"error_code":"radar_out_of_rollcall_scope", "distance":1425.8}`。服务端直接将"当前提交点距离教师手机的真实距离（米）"完整返回！

利用这一泄露，系统在 `radar.rs` 中执行多边定位（Multilateration）：

- **探针采样：** 向地球（或指定区域）预置的锚点提交探针坐标，收集 ≥3 组有效的 `(point, distance)`。
- **3D 几何闭式粗解：** 采用地心空间直角坐标（ECEF）建立线性球交方程，避免平面局部切投影在较大距离时的曲率失真。
- **Levenberg-Marquardt (LM) 非线性优化：** 引入软 L1 鲁棒核函数（Huber/Soft-L1），快速迭代最小化距离残差：$\min \sum \rho\left(\|P - P_i\|_{haversine} - d_i\right)$，收敛出教师端高精度坐标（精度达 1~5 米内）。
- **信标签名防伪：** 若 `use_beacon=true`，读取 `/lite` 的 `beacon_nonce`，以 `md5(nonce + deviceId + userId + ts),ts` 生成 `radarSignal` 伴随上报。

2. 数字点名（Number）：泄露读取与安全"严格单飞"（Unknown-safe Sequential）爆破

途径 A：点名册泄露提取

直接拉取花名册 `GET /api/rollcall/{id}/student_rollcalls`。若老师端配置失误或班内已有同学签到，花名册内常包含 `number_code`。需兼容数字转字符串（如整数 `123` 需格式化为 `"0123"`）。

途径 B：单飞安全爆破

若无泄露，进行 0000~9999 轮询。**杜绝高并发**（严防触发 WAF 封禁或并发竞争），维持**单飞请求**（当前在途请求仅为 1），并按 5 类状态精细化分支：

响应分类	HTTP 状态与特征	调度动作与安全控制
`Success`	2xx 且明确包含 `success:true` 或 `on_call`	立即停止爆破，进入花名册复核并向群组广播已解口令。
`Wrong`	400 / 409 / 422 或 Body 包含“错误/不存在”	当前码错误，递增测试下一口令（\(N+1\)）。
`Transient`	429（限流）/ 408 / 500~504 服务端抖动	触发单码指数退避重试（Sleep 后继续试当前码），不可盲目跳过。
`Fatal`	401 / 403 / 重定向至登录页（SSO/Login）	会话已失效，**立即全面熔断退出**，触发重新登录防死循环。
`Ambiguous`	2xx 但 Body 为空、非 JSON 或未知结构	视为“已提交但未确认”，**立即停止尝试新码**，转入花名册复核。

3. 自主点名（Self-Registration）与 二维码（QR Code）方法论

自主点名： 直接调用 `PUT /api/rollcall/{id}/answer_self_registration_rollcall`（空 JSON Body），属于畅课系统开销最小、稳定性最高的一种点名方式。

动态二维码逆向本质： 二维码 Payload 固定为 42 位字符（10 位 Unix 时间戳 + 32 位 MD5 哈希）。由于该码几秒一刷新，纯客户端单兵无法无中生有。目标项目提供了两类思路：① **群组/VPS 众包中转：** 教室内任一同学扫到二维码后，Token 自动上传自建 VPS 缓存，挂机学生通过接口并发拉取提交；② **助教接口代签：** 若配置了助教账号，直接从 `GET /api/course/{cid}/rollcall/{id}/qr_code` 提取动态 Token 派发。

4. 权威查册确认闭环（`recheck_on_call_fine`）

> **核心防护法则：** 绝不信任单次 HTTP 状态码（200 OK 经常伴随业务业务异常或虚假拦截）。所有签到操作执行完毕后，必须无条件调用 `GET /api/rollcall/{id}/student_rollcalls`，在学生花名册数组中匹配本账号的 `user_no` / `user_id`，严格确保 `status == "on_call_fine"` 才视为最终成功。

三、 本项目（usst-jwgl-client）与 auto-Tronclass 对比

维度	目标项目 auto-Tronclass-APP	本项目 usst-jwgl-client（掌上理工）
核心定位	多租户、多学生、轻量全自动挂机/答题工具。	上理全功能原生客户端（教务、课表、空教室、实验课、畅课）。
雷达签到能力	**空 Body 探针 + 全球测距 LM 非线性反解**，完全脱离环境与位置依赖。	采纳校园 9 大教学楼 GCJ-02 预置基准库或教师 Beacon，依赖课表房间匹配。
二维码签到	VPS Token 众包中转、助教接口、手动扫码。	**独创智慧录播流（HTTP-FLV）关键帧智能截取 + ML Kit 自动识码**（惊艳特色）。
数字签到策略	花名册提取（整型自动补零） + **单飞顺序爆破与状态分类。**	`RollcallNumberCodeLookup` 从详情取码，若无则弹窗通知手动输入。
自主点名	完整支持（空 Body PUT）。	尚未支持（当前仅匹配 radar、number、qr_code）。
成功验证	严格二次查册，确认自身处于 `on_call_fine` 状态。	主要依赖提交接口 HTTP 200 返回，缺少权威查册闭环。
后台生命周期	精确闹钟唤醒，主动应对 Android 15 `dataSync` 6 小时配额。	**深度整合时刻表**（课前 5 分钟精准唤醒，课后自动停止释放资源）。

四、 为「掌上理工」量身定制的演进路线图

Phase 1：低成本·高收益快速落地（建议立即实施）

1. **补齐自主点名：** 增加 `answerSelfRegistration()`，在 `RollcallMonitorService` 增加类型匹配，实现零成本全自动签到。
2. **数字码整型兼容：** 修复 `RollcallNumberCodeLookup`，将纯数字类型强制格式化为 4 位字符（`%04d`），避免丢失前导 0。
3. **引入权威复核闭环：** 编写 `recheckOnCallFine()`，各签到完成后核对 `student_rollcalls`，保证状态置信度。

Phase 2：数字签到防封禁单飞爆破机制

1. **单飞爆破协程管道：** 当详情未带码时，启动单线程 Coroutine 进行 0000~9999 顺序轮询，单次并发严格限制为 1。
2. **精细化退避与熔断：** 遇到 429 暂停 1000ms 重试；遇到 401 立即熔断通知用户登录过期；遇到模糊返回立即终止尝试并复查。
3. **设备指纹隔离：** 多账号代签时，为每个学号持久化独立 UUID 作为 `deviceId`，避免同硬件高频特征风控。

Phase 3：雷达签到“三阶梯策略”与校园定位算子

1. **第一阶（空探针）：** 优先发送空 Body，若租户未开启强校验则直接完成，节省 GPS 采样开销。

2. **第二阶（预置教学楼）：** 沿用现有 9 大教学楼坐标，覆盖 90% 常规线下教学。

3. **第三阶（校园三角定位微算器）：** 当返回越界并携带 `distance` 时，以 516 号一教、图文信息中心、体育馆为 3 个锚点探测，用轻量 Trilateration 解出真实经纬度。

Phase 4：系统资源规范与 Android 15 配额防护

1. **Android 15 dataSync 限制：** Android API 35 规定滚动 24 小时内前台服务上限为 6 小时。需在服务中加入运行统计，超时主动降级为单次闹钟探测。

2. **多账号本地互助：** 主账号一旦成功解算口令或坐标，在单次轮询内存中共享给其他账号，避免多账号重复暴力运算。

五、 关键模块 Kotlin 落地实现参考

```kotlin
// 1. 权威结果复核闭环（严杜虚假成功）
suspend fun recheckOnCallFine(rollcallId: Long, userStudentId: String): Boolean = withContext(Dispatcher
    val res = get("/api/rollcall/$rollcallId/student_rollcalls")
    val json = parseJsonObject(res) ?: return@withContext false
    val roster = json.getAsJsonArray("student_rollcalls") ?: return@withContext false

    roster.any { el →
        val item = el.asJsonObject
        val uid = item.get("user_no")?.asString ?: item.get("user_id")?.asString
        val status = item.get("status")?.asString ?: item.get("rollcall_status")?.asString
        uid.equals(userStudentId, ignoreCase = true) && status == "on_call_fine"
    }
}

// 2. 自主签到与空探针集成
suspend fun answerSelfRegistration(rollcallId: Long): RollcallWriteResult {
    return putJson("/api/rollcall/$rollcallId/answer_self_registration_rollcall", JsonObject())
}
```

安全与合规红线提示： 自动签到功能属于辅助便利性工具。在代码落地中必须恪守：① 严格单飞请求节奏，严禁发起并发 DDoS 流量；② 遭遇 401/403 时立即熔断终止；③ 提醒学生遵守学校考勤规章，保留必要的手动复核与操作日志。